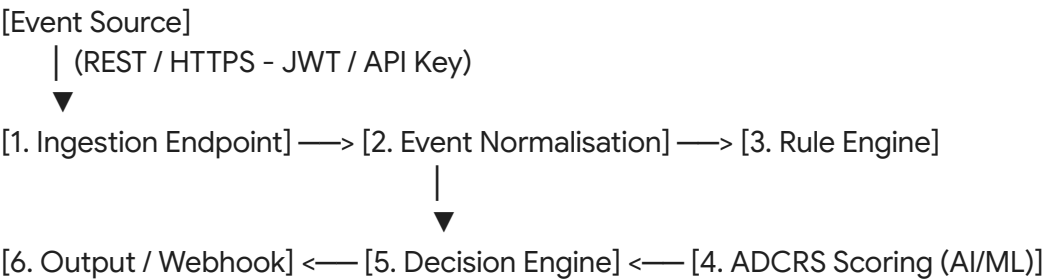


PHOENIX – Threat Analysis API Data Exchange Specification

Author: Vipul
Project: PHOENIX (Capstone B)
Deliverable: Threat Analysis Integration – API Data Exchange Specification
Aligned Artifacts: Integration Design (Mannat), Sequence Diagram & Test Plan (Dilano)

1. Architectural Interfaces Overview



2. Authentication, Authorization & Security Requirements

Control	Implementation Standard	Enforcement Mechanism
Protocol	TLS 1.3 only (HTTPS)	Rejects unencrypted HTTP traffic at gateway (403 Forbidden).
Authentication	JSON Web Tokens (JWT) via Authorization: Bearer <token>	Verified on all private routes (SIT-01, SIT-02).
RBAC Roles	authority_admin, analyst, ingest_service, public_viewer	Principle of Least Privilege via scope validation (SIT-03).

Rate Limiting	Token Bucket Algorithm (SIT-05)	100 req/min for services; 20 req/min for standard users.
Payload Integrity	SHA-256 HMAC (Header: X-PHOENIX-Signature)	Required for inter-service communication (TEAVS $\rightarrow$ ADCRS).

3. API Endpoints Specification

3.1 Ingest Security Event

- **Endpoint:** POST /api/v1/threats/ingest
- **RBAC Role:** ingest_service, authority_admin
- **Description:** Receives raw security events from TEAVS, IoT sensors, auth logs, or external threat feeds.

Request Headers:

HTTP
Content-Type: application/json
Authorization: Bearer <jwt_token>
X-PHOENIX-Signature: <sha256_hmac_hex>

Request Payload Schema:

```
JSON
{
  "$schema": "http://json-schema.org/draft-07/schema#",
  "type": "object",
  "properties": {
    "event_id": { "type": "string", "pattern": "^EVT-[A-Za-z0-9]{3,12}$" },
    "event_type": {
      "type": "string",
      "enum": [
        "login_activity",
        "api_abuse",
        "phishing_report",
        "ddos_spike",
        "iot_anomaly",
        "alert_tampering",

```

```

        "fraud_claim"
    ]
},
"timestamp": { "type": "string", "format": "date-time" },
"source": {
    "type": "string",
    "enum": ["TEAVS", "API_GATEWAY", "USER_LOGS", "IOT_CLUSTER", "SYS_AUDIT"]
},
"event_data": {
    "type": "object",
    "required": ["source_ip", "target_resource"],
    "properties": {
        "source_ip": { "type": "string", "format": "ipv4" },
        "target_resource": { "type": "string" },
        "failed_attempts": { "type": "integer", "minimum": 0 },
        "payload_hash": { "type": "string", "pattern": "^[a-fA-F0-9]{64}$" },
        "geo_location": {
            "type": "object",
            "properties": {
                "latitude": { "type": "number" },
                "longitude": { "type": "number" }
            }
        }
    }
}
},
"required": ["event_id", "event_type", "timestamp", "source", "event_data"],
"additionalProperties": false
}

```

Successful Response (202 Accepted):

```

JSON
{
    "status": "success",
    "code": 202,
    "message": "Event queued and validated for normalisation",
    "data": {
        "event_id": "EVT-001",
        "received_at": "2026-08-20T08:43:53Z",
        "tracking_id": "TRK-98124-PHX"
    }
}

```

3.2 ADCRS Scoring & Prediction (Internal Inter-Service)

- **Endpoint:** POST /api/v1/internal/adcrs/score
- **RBAC Role:** internal_ml_service
- **Description:** Exchanges normalised threat indicators with the AI/ML model for multi-hazard cyber-physical risk scoring.

Request Payload:

```
JSON
{
  "event_id": "EVT-001",
  "normalised_features": {
    "threat_category": "login_activity",
    "frequency_zscore": 3.42,
    "geo_risk_weight": 0.78,
    "active_disaster_zone": true,
    "disaster_type": "wildfire"
  }
}
```

Response Payload (200 OK):

```
JSON
{
  "event_id": "EVT-001",
  "threat_classification": "Login Attack",
  "risk_score": 82,
  "confidence_score": 0.91,
  "anomaly_flag": true,
  "model_version": "xgb_v1.4.2"
}
```

3.3 Fetch Threat Analysis Details / Alert Output

- **Endpoint:** GET /api/v1/threats/{event_id}
- **RBAC Role:** authority_admin, analyst, public_viewer
- **Description:** Returns the processed threat result for the web dashboard, audit logs, and alert system.

Response Payload (200 OK):

```
JSON
{
```

```

"event_id": "EVT-001",
"threat_type": "Login Attack",
"severity": "High",
"risk_score": 82,
"confidence_score": 0.91,
"recommended_action": "lock_account",
"status": "detected",
"execution_metadata": {
  "processed_at": "2026-08-20T08:43:54Z",
  "rule_triggered": "RULE_AUTH_BRUTE_FORCE",
  "notification_dispatched": true,
  "signature": "c8f5d0251147a3..."
}
}

```

4. Standard Error Response Structure

All endpoints enforce secure error handling (SIT-06) to avoid stack-trace leaking:

```

JSON
{
  "status": "error",
  "code": 400,
  "error_type": "VALIDATION_FAILED",
  "message": "Invalid IPv4 address format in event_data.source_ip",
  "timestamp": "2026-08-20T08:43:53Z"
}

```

5. Risk Score & Threat Action Matrix

Risk Score Range	Severity Level	Confidence Range	Triggered Mitigation Action	Notification Required
0 – 39	Low	\$\ge 0.50\$	log_and_monit or	No

40 – 69	Medium	\$\ge 0.70\$	flag_for_review, challenge_mfa	No
70 – 89	High	\$\ge 0.85\$	lock_account, rate_limit_ip	Yes (Authority Alert)
90 – 100	Critical	\$\ge 0.90\$	isolate_node, revoke_tokens, broadcast_alert	Yes (Public & Authority)

6. Alignment with Test Cases

- **DVT-01 to DVT-06:** Validated via the JSON Schema constraints in Section 3.1.
- **SIT-01 to SIT-05:** Enforced by JWT auth headers, strict RBAC matrices, and rate-limit headers.
- **FIT-05 to FIT-09:** Satisfied by the contract responses in Sections 3.2 and 3.3.